

PHISHING EMAIL DETECTION & AWARENESS SYSTEM

*Rapport Professionnel de Détection
et de Sensibilisation au Phishing*

Réalisé par : IGNEVOURYA Ehno Hermann

Stage : CyberSécurité

Structure: Future Interns

Date : 20 Mai 2026

Table des matières

INTRODUCTION	4
CONTEXTE ET PROBLÉMATIQUE.....	4
OBJECTIFS DU PROJET	5
Objectif général.....	5
Objectifs spécifiques.....	5
I. PRÉSENTATION GÉNÉRALE DU PHISHING	6
II. TYPES DE PHISHING	6
II.1 Email Phishing	6
A. Caractéristiques :.....	7
II.2 Spear Phishing.....	7
II.3 Whaling	7
II.4 Smishing.....	7
II.5 Vishing.....	7
III. TECHNIQUES UTILISÉES PAR LES CYBERCRIMINELS.....	8
III.1 Spoofing d'adresse email	8
III.2 Faux domaines	8
III.3 Liens malveillants.....	8
III.4 Pièces jointes malveillantes	8
III.5 Ingénierie sociale	8
VI. OUTILS UTILISÉS	9
V. MÉTHODOLOGIE D'ANALYSE.....	9
Étape 1 : Collecte des emails	9
Étape 2 : Analyse visuelle.....	9
Étape 3 : Analyse des headers	10
Étape 4 : Classification	10
VI. ANALYSE DÉTAILLÉE DES EMAILS PHISHING	10
Exemple 1 : Faux email bancaire	10
a. Description.....	10
b. Indicateurs observés.....	10
c. Analyse.....	11
d. Classification.....	11
Exemple 2 : Faux email Microsoft 365.....	11

A. Description.....	11
B. Indicateurs observés.....	11
C. Risques	11
D. Classification.....	11
Exemple 3 : Email suspect de livraison.....	11
a. Description.....	11
b. Techniques utilisées.....	12
c. Classification.....	12
VII. ANALYSE DES HEADERS EMAIL	12
1. Champs importants.....	12
2. Analyse SPF	12
3. Analyse DKIM.....	13
4. Analyse des adresses IP	13
VIII. CLASSIFICATION DES EMAILS.....	13
a. Safe.....	13
b. Suspicious.....	13
c. Phishing.....	13
IX. IMPACTS ET RISQUES LIÉS AU PHISHING	13
1) Risques pour les utilisateurs	13
2) Risques pour les entreprises	13
X. MESURES DE PRÉVENTION ET PROTECTION	14
XI. SENSIBILISATION DES UTILISATEURS	14
1) Les utilisateurs doivent être capables de :.....	14
2) Bonnes pratiques de sensibilisation.....	14
XII. BONNES PRATIQUES EN ENTREPRISE	15
CONCLUSION.....	16

INTRODUCTION

Le phishing est aujourd'hui l'une des cyberattaques les plus répandues dans le monde numérique. Cette technique de cybercriminalité consiste à tromper les utilisateurs afin de leur soutirer des informations sensibles telles que des mots de passe, des données bancaires ou encore des informations personnelles.

Les attaques par phishing représentent une menace majeure tant pour les particuliers que pour les entreprises. Les cybercriminels exploitent principalement la manipulation psychologique et l'ingénierie sociale pour inciter les victimes à agir rapidement, sans vérifier l'authenticité des messages reçus.

Avec l'augmentation de l'utilisation des services numériques, des plateformes bancaires en ligne et des services cloud, les attaques par phishing deviennent de plus en plus sophistiquées et difficiles à détecter.

Ce projet a pour objectif d'étudier les techniques de phishing, d'identifier les indicateurs de compromission dans les emails suspects et de proposer des mesures efficaces de prévention et de sensibilisation.

CONTEXTE ET PROBLÉMATIQUE

Les entreprises dépendent fortement des communications électroniques pour leurs activités quotidiennes. Les emails sont devenus des moyens essentiels de communication professionnelle. Cependant, cette dépendance expose également les organisations à des risques importants liés aux cyberattaques.

Les cybercriminels utilisent les emails pour :

- Voler des identifiants ;
- Diffuser des logiciels malveillants ;
- Compromettre des comptes utilisateurs ;
- Accéder à des données sensibles ;
- Réaliser des fraudes financières.

La problématique principale est que de nombreux utilisateurs ne possèdent pas les connaissances nécessaires pour identifier les emails frauduleux.

Le manque de sensibilisation favorise :

- Les vols d'informations ;

- Les compromissions de systèmes ;
- Les pertes financières ;
- Les atteintes à la réputation des entreprises.

Ainsi, il devient essentiel de développer des systèmes de détection et des campagnes de sensibilisation efficaces.

OBJECTIFS DU PROJET

Les principaux objectifs de ce projet sont :

Objectif général

Mettre en place une étude complète permettant de détecter les emails phishing et de sensibiliser les utilisateurs aux risques liés à ces attaques.

Objectifs spécifiques

- Comprendre le fonctionnement des attaques phishing ;
- Identifier les indicateurs d'un email frauduleux ;
- Analyser les headers email ;
- Classifier les emails selon leur niveau de danger ;
- Étudier les techniques utilisées par les cybercriminels ;
- Fournir des recommandations de sécurité ;
- Sensibiliser les utilisateurs aux bonnes pratiques.

I. PRÉSENTATION GÉNÉRALE DU PHISHING

Le phishing est une technique de fraude informatique reposant principalement sur l'ingénierie sociale.

Les cybercriminels se font passer pour :

- Une banque ;
- Un service administratif ;
- Une entreprise connue ;
- Un collègue ;
- Un service de livraison ;
- Une plateforme en ligne.

L'objectif est d'inciter la victime à :

- Cliquer sur un lien malveillant ;
- Télécharger une pièce jointe infectée ;
- Fournir des informations confidentielles.

Le phishing exploite généralement :

- l'urgence ;
- la peur ;
- la confiance ;
- La curiosité.

Exemple

:

“Votre compte sera suspendu dans les prochaines heures si vous ne confirmez pas vos informations.”

II. TYPES DE PHISHING

II.1 Email Phishing

Forme classique utilisant des emails frauduleux envoyés à un grand nombre de victimes.

A. Caractéristiques :

- Faux logo ;
- Fausse identité ;
- Liens suspects ;
- Message urgent.

II.2 Spear Phishing

Attaque ciblée visant une personne ou une entreprise spécifique. Les attaquants collectent des informations sur la victime afin de rendre l'attaque crédible.

II.3 Whaling

Type de spear phishing ciblant les dirigeants d'entreprise ou les hauts responsables.

Objectif :

- fraude financière ;
- accès stratégique ;
- vol de données sensibles.

II.4 Smishing

Phishing réalisé via SMS.

Exemple

:

“Votre colis est bloqué. Cliquez ici.”

II.5 Vishing

Attaque utilisant les appels téléphoniques.

Les cybercriminels se font passer pour :

- une banque ;

- un support technique ;
- Une administration.

III. TECHNIQUES UTILISÉES PAR LES CYBERCRIMINELS

III.1 Spoofing d'adresse email

Les attaquants falsifient l'adresse de l'expéditeur afin de faire croire que l'email provient d'une source légitime.

III.2 Faux domaines

Exemples :

- paypal.com au lieu de paypal.com
- micros0ft.com au lieu de microsoft.com

III.3 Liens malveillants

Les liens redirigent vers :

- De fausses pages de connexion ;
- Des sites infectés ;
- Des téléchargements malveillants.

III.4 Pièces jointes malveillantes

Les fichiers joints peuvent contenir :

- Des ransomwares ;
- Des chevaux de Troie ;
- Des scripts malveillants.

III.5 Ingénierie sociale

Technique de manipulation psychologique exploitant :

- La peur ;
- L'urgence ;
- L'autorité ;
- La confiance.

VI. OUTILS UTILISÉS

Email Header Analyzer	Analyse des en-têtes email
Browser Developer Tools	Vérification des URLs
Microsoft Word	Rédaction du rapport
GitHub	Hébergement du projet
Dataset phishing	Analyse des exemples

V. MÉTHODOLOGIE D'ANALYSE

La méthodologie suivie dans ce projet comprend plusieurs étapes.

Étape 1 : Collecte des emails

Des exemples d'emails légitimes et malveillants ont été collectés.

Étape 2 : Analyse visuelle

Observation :

- Du contenu ;
- Du ton utilisé ;
- Des liens ;
- Des pièces jointes ;
- Des fautes grammaticales.

Étape 3 : Analyse des headers

Étude :

- Des serveurs d'envoi ;
- Des adresses IP ;
- Des signatures SPF/DKIM.

Étape 4 : Classification

Les emails sont classés :

- Safe ;
- Suspicious ;
- Phishing.

VI. ANALYSE DÉTAILLÉE DES EMAILS PHISHING

Exemple 1 : Faux email bancaire

a. Description

Un email prétendant provenir d'une banque demande à l'utilisateur de confirmer ses informations bancaires.

b. Indicateurs observés

Expéditeur	Domaine suspect
URL	Lien non officiel
Ton	Urgent
Contenu	Menace de suspension

c. Analyse

Le message utilise la peur afin d'inciter l'utilisateur à agir rapidement.

Le lien redirige vers une fausse page de connexion destinée au vol d'identifiants.

d. Classification

✓ PHISHING

Exemple 2 : Faux email Microsoft 365

A. Description

L'email demande à l'utilisateur de renouveler son mot de passe.

B. Indicateurs observés

- URL raccourcie ;
- fautes grammaticales ;
- domaine falsifié ;
- Demande inhabituelle.

C. Risques

- vol d'accès Microsoft 365 ;
- compromission du compte ;
- accès aux données professionnelles.

D. Classification

✓ PHISHING

Exemple 3 : Email suspect de livraison

a. Description

Un faux service de livraison demande le paiement de frais supplémentaires.

b. Techniques utilisées

- urgence ;
- faux suivi colis ;
- Faux site de paiement.

c. Classification

- ✓ SUSPICIOUS

VII. ANALYSE DES HEADERS EMAIL

Les headers email permettent d'identifier la véritable origine d'un message.

1. Champs importants

From	Expéditeur affiché
Return-Path	Adresse réelle
Received	Serveurs traversés
SPF	Validation du domaine
DKIM	Signature cryptographique

2. Analyse SPF

SPF permet de vérifier si le serveur d'envoi est autorisé.

Exemple :

SPF = FAIL

Cela indique une possible usurpation.

3. Analyse DKIM

DKIM permet de vérifier l'intégrité du message.

Un DKIM invalide peut signaler une falsification.

4. Analyse des adresses IP

Les IP peuvent être utilisées pour :

- identifier le pays d'origine ;
- détecter des serveurs suspects.

VIII. CLASSIFICATION DES EMAILS

a. Safe

Emails légitimes ne présentant aucun signe suspect.

b. Suspicious

Emails contenant certains éléments douteux mais sans preuve claire d'attaque.

c. Phishing

Emails frauduleux visant à voler des informations ou compromettre un système.

IX. IMPACTS ET RISQUES LIÉS AU PHISHING

1) Risques pour les utilisateurs

- Vol de mot de passe ;
- Perte financière ;
- Vol d'identité ;
- Infection malware.

2) Risques pour les entreprises

- Fuite de données ;

- Compromission du réseau ;
- Arrêt des activités ;
- Atteinte à la réputation ;
- Pertes financières importantes.

X. MESURES DE PRÉVENTION ET PROTECTION

- Pour les utilisateurs

Vérifier l'adresse email, toujours vérifier le domaine réel de l'expéditeur.

- Vérifier les liens

Passer la souris sur le lien avant de cliquer.

- Ne jamais partager ses mots de passe

Aucune entreprise sérieuse ne demande un mot de passe par email.

- Utiliser l'authentification multifacteur

Le MFA réduit considérablement les risques.

- Pour les entreprises

Déployer SPF, DKIM et DMARC qui permettra de réduire les usurpations d'identité.

- Former les employés : la sensibilisation est essentielle.
- Utiliser des solutions anti-phishing : filtrage des emails suspects.
- Effectuer des simulations phishing : Permet de tester la vigilance des employés.

XI. SENSIBILISATION DES UTILISATEURS

La sensibilisation est un élément fondamental de la cybersécurité.

1) Les utilisateurs doivent être capables de :

- Reconnaître un email suspect ;
- Signaler les incidents ;
- Éviter les comportements dangereux.

2) Bonnes pratiques de sensibilisation

- Formations régulières ;

- Affiches de sécurité ;
- Campagnes internes ;
- Exercices pratiques ;
- Simulations of phishing.

XII. BONNES PRATIQUES EN ENTREPRISE

- Politique de sécurité email : définir des règles strictes d'utilisation des emails ;
- Gestion des accès : limiter les privilèges des utilisateurs ;
- Surveillance des activités : détecter rapidement les comportements anormaux ;
- Mise à jour des systèmes : réduire les vulnérabilités exploitables.

CONCLUSION

Le phishing représente aujourd'hui une menace majeure pour les particuliers et les entreprises. Les cybercriminels utilisent des techniques de plus en plus sophistiquées afin de contourner les mesures de sécurité traditionnelles.

Ce projet a permis :

- d'analyser plusieurs exemples d'emails phishing ;
- d'identifier les principaux indicateurs de fraude ;
- de comprendre les techniques d'ingénierie sociale ;
- de proposer des mesures efficaces de prévention.

La meilleure défense contre le phishing repose sur :

- la sensibilisation ;
- la vigilance ;
- la formation continue ;
- L'utilisation de solutions de sécurité adaptées.

Les entreprises doivent investir davantage dans la cybersécurité et la formation des utilisateurs afin de réduire les risques liés aux cyberattaques.